

Лабораторная работа 4.

Вопросы безопасности распределенной модельной клиент-серверной ИС

Цель работы: изучение аспектов безопасной работы и защиты информационного обмена в рамках модельной клиент-серверной ИС

Вводная информация

Администратор предприятия принял решение имплементировать ИС собственной разработки для удаленного управления серверами (сервером) предприятия. Чтобы ввести в заблуждение всех потенциальных нарушителей (или злоумышленников), он отказался от всех популярных способов удаленного доступа и управления серверной инфраструктурой – использование SSH (Secure Shell), RDP (Remote Desktop Protocol), и иных востребованных решений удаленного взаимодействия. Вместо этого администратор разработал свою собственную ИС управления серверами. Общая концепция взаимодействия клиента и сервера в разработанной администратором ИС приведены на рис .1.

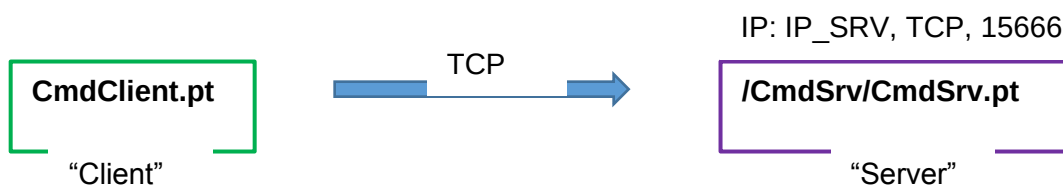


Рис. 1. Схема работы модельной клиент-серверной ИС.

Серверное приложение запускается на управляемом сервере предприятия на порту 15666, для взаимодействия с клиентом используется протокол TCP. Имя пользователя-администратора и пароль жестко настраиваются в программном коде серверного приложения. IP-адрес и порт для подключения к серверу жестко настраиваются в клиентском приложении. При выполнении подключения клиента ИС к серверу в интерактивном режиме запрашиваются логин и пароль администратора, после чего система переходит в командный режим администрирования сервера (выполнение «специальных» и прочих команд).

Задания

0. **Напоминаем**, что выполнение каждого задания должно сопровождаться в отчете детальным описанием полученных результатов и приложением копий экранов (фрагментов копий экранов), демонстрирующих получение этих результатов.

1. Запустите приложение ‘Terminal’ на рабочей станции ‘Client’. Откройте текст клиентского приложения (находится в домашнем каталоге пользователя ‘kali’). Посмотрите текст программного компонента (команда ‘less’, текстовый редактор ‘nano’, иные способы). При необходимости отредактируйте текст для указания правильного IP-адреса и порта подключения к серверу.

2. Выполните вход с использованием учетной записи ‘root’ на рабочую станцию ‘Server’. Найдите программное приложение серверной компоненты ИС (в каталоге ‘/CmdSrv/’ приложение ‘CmdSrv.pt’). Это программное приложение автоматически запускается при загрузке ОС сервера.

Определите, какой пользователь является владельцем запущенного на машине ‘Server’ серверной компоненты модельной ИС (команда ‘ps aux’).

Изучите программный код серверной компоненты, определите указанные в программном коде логин и пароль для подключения к серверу модельной ИС.

Подсказка – из числа «специальных» команд реализована только команда ‘interfaces’, которая выводит настройки сетевых интерфейсов обслуживаемого сервера.

3. На рабочей станции ‘Client’ запустите анализатор трафика Wireshark (с указанием рабочего интерфейса для анализа ‘eth0’). Дождитесь начала его работы.

Запустите клиентское приложение модельной ИС и выполните вход в систему с указанием требуемых логина и пароля администратора. После удачного входа выполните «специальную» команду ‘interfaces’. Посмотрите результат вывода. Завершите сеанс при помощи команды ‘quit’.

4. Остановите перехват и анализ сетевого обмена в Wireshark. Изучите транспортируемые данные полезных нагрузок протокола TCP в ходе обмена между клиентом и сервером модельной ИС. Раскройте детали обмена при помощи опции ‘Show

packet bytes' приложения Wireshark (рис. 2). Выполните это действие поэтапно для всех перехваченных фрагментов сетевого обмена между клиентским и серверным приложением ИС.

Укажите обнаруженные особенности сетевого обмена и его «надежность» (стойкость) для расшифровки и анализа третьим лицом (нарушителем).

5. На основании собранной информации, сделайте следующие выводы и заключения:

- относительно безопасности процесса идентификации и аутентификации
- относительно наличия этапа авторизации в серверном приложении модельной ИС
- относительно безопасности интерактивной работы на этапе исполнения команд (с учетом анализа программного кода серверной компоненты ИС)

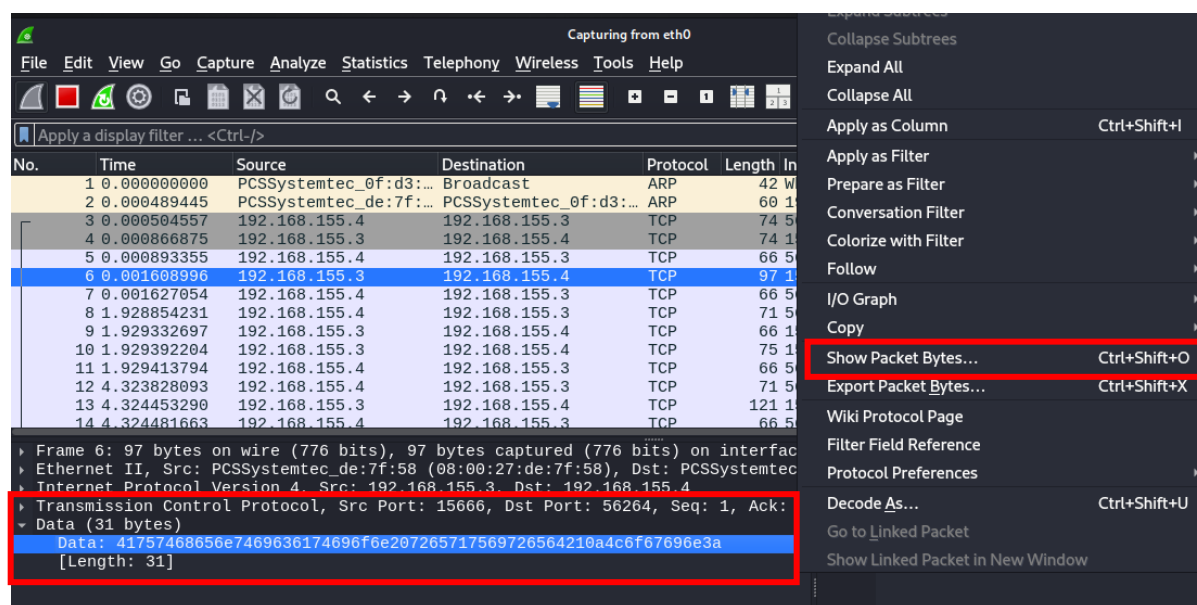


Рис. 2. Анализ обмена (полезной нагрузки протокола TCP)
клиент-серверной ИС.

6. Предложите и реализуйте (программно, изменив исходный текст клиентского и серверного приложения модельной ИС) ваши собственные идеи, направленные на обеспечение большей защищенности клиент-серверного взаимодействия и работы клиентского и серверного приложения модельной ИС:

- в части процесса идентификации и аутентификации

- в части этапа авторизации в серверном приложении модельной ИС
- в части работы серверного приложения модельной ИС
- в части выполнения команд серверным приложением в интерактивном режиме работы модельной ИС

7. Оформите все результаты в виде отчета о выполненной лабораторной работе. Продемонстрируйте преподавателю работающие изменения программного кода клиентской и серверной компоненты модельной ИС, соответствующие запланированным и внесенным изменениям. При необходимости, дополните результаты демонстрацией перехвата сетевого обмена между клиентом и сервером модельной ИС при помощи анализатора Wireshark (результаты демонстрации следует включить в отчет).